Saudi GRC Platform

Data Model

Source: `data-model.md`

04 — Data Model and Entity Relationship Design

Logical data model of the TSS GRC platform, anchored to the actual JPA entities and SQL Server tables.

Conventions:

- Every business entity extends `BaseEntity` adding: `id` (BIGINT IDENTITY, PK), `organisationId` (tenant scope), `externalId` (URL-safe code), `isDeleted` SMALLINT (soft delete), `isActive`, `createdAt/By`, `updatedAt/By`, `deletedAt/By`, `rowVersion`.
- Bilingual fields: every user-visible string has `*_en` and `*_ar`.
- Tenancy: `organisationId` indexed on every query. `TenantContext` thread-local enforces filter.
- Soft delete: `@Where(clause="is_deleted = 0")` on every entity.
- Status: every state-machine entity has `status NVARCHAR(20)` + audit timestamps per terminal transition.

Core entities

Organization

- **AR**: ■■■■■■■ | **EN**: Organisation
- Tenant boundary. Every other row references it.
- **Table**: `platform.organisations`
- **Fields**: `id`, `external_id` (slug), `name_en`, `name_ar`, `registration_number` (CR), `vat_number`, `sector`, `country` (ISO3), `parent_organisation_id`, `status`, `branding_json`, `effective_from`, `effective_to`.
- **API**: `Organisation`
- **Relations**: 1→N every other business entity.

Department

- **AR**: ■■■■■■■ | **EN**: Department
- Internal org chart.
- **Table**: `iam.departments`
- **Fields**: `id`, `organisation_id`, `parent_department_id`, `name_en`, `name_ar`, `manager_user_id`, `cost_centre`.

User

- **AR**: ■■■■■■■■ | **EN**: User
- **Table**: `iam.users`
- **Fields**: `username`, `email`, `display_name_en`, `display_name_ar`, `phone`, `password_hash`, `mfa_enabled`, `mfa_method`, `default_org_id`, `last_login_at`, `failed_login_count`, `locked_until`, `roles` (M:N via `iam.user_roles`).

Role

- **AR**: ■■■■■ | **EN**: Role
- **Table**: `iam.roles`
- **Fields**: `name`, `description_en`, `description_ar`, `permissions` (M:N via `iam.role_permissions`).
- See `/08-RBAC/` for the full role catalogue.

Committee

- **AR**: ■■■■■■ | **EN**: Committee
- **Table**: `admin.committees`
- **Fields**: `name_en`, `name_ar`, `description_en`, `description_ar`, `charter_en`, `charter_ar`, `members_json`, `cadence`, `chair_user_id`, `secretary_user_id`, `status` (ACTIVE | DISSOLVED).
- **Children**: `admin.committee_meetings`.

Service

- **AR**: ■■■■■■ | **EN**: Critical Service
- The unit of BCM scoping.
- **Table**: `bcm.critical_processes`
- **Fields**: `name_en`, `name_ar`, `criticality` (LOW | MEDIUM | HIGH | CRITICAL), `owner_user_id`, `business_function`, `regulatory_drivers`.

Process

- **AR**: ■■■■■■■ | **EN**: Business Process
- Sub-unit of service.
- **Table**: `bcm.business_processes` (where applicable).

Asset

- **AR**: ■■■■■ | **EN**: Asset
- **Table**: `cyber.cyber_assets`
- **Fields**: `name_en`, `name_ar`, `asset_type` (SERVER | NETWORK | DB | APPLICATION | OT_ICS | CLOUD), `classification`, `owner`, `location`, `criticality`, `residency`.

Application

- Subset of Asset (`asset_type = 'APPLICATION'`).

Data Asset

- **AR**: ■■■■■ ■■■■■■■ | **EN**: Data Asset
- **Table**: `cyber.data_assets` (or `evidence.data_assets`)
- **Fields**: `name_en`, `name_ar`, `classification` (PUBLIC | INTERNAL | CONFIDENTIAL | RESTRICTED), `pii_flag`, `residency`, `owner`, `retention_policy`.

Personal Data Processing Activity (ROPA)

- **AR**: ■■■■ ■■■■■■ ■■■■■■■■ ■■■■■■■ | **EN**: Processing Activity
- **Table**: `privacy.processing_activities`

- **Fields**: `code` (ROPA-XXX), `activity_name_en`, `activity_name_ar`, `purpose_en`, `purpose_ar`, `lawful_basis`, `data_categories`, `data_subjects`, `source_asset_id`, `recipients`, `retention_days`, `cross_border_flag`, `last_reviewed_at`, `business_owner`.

Supplier (Vendor)

- **AR**: ■■■■■■ | **EN**: Vendor
- **Table**: `scm.vendors`
- **Fields**: `vendor_name`, `vendor_name_ar`, `vendor_type`, `country`, `risk_rating`, `criticality`, `status`, `contract_end_date`.

Contract

- **AR**: ■■■■■ | **EN**: Contract
- **Table**: `scm.contracts`
- **Fields**: `vendor_id`, `contract_code`, `effective_from`, `effective_to`, `value_sar`, `status`.

Dependency

- **Table**: `scm.dependencies`, `bcm.process_dependencies`
- **Fields**: `source_type`, `source_id`, `target_type`, `target_id`, `dependency_kind`, `criticality`.

Risk

- **Table**: `risk.risks`
- **Fields**: `risk_code`, `title_en`, `title_ar`, `category`, `subcategory`, `inherent_likelihood`, `inherent_impact`, `residual_likelihood`, `residual_impact`, `treatment_strategy`, `risk_owner`, `appetite_band`, `status`.

Control

- **Table**: `cyber.cyber_controls` (cybersecurity); `compliance.controls` (general); `evidence.controls` (evidence catalog)
- **Fields**: `framework_name`, `domain`, `control_number`, `title_en`, `title_ar`, `procedure_en`, `control_type` (PREVENTIVE | DETECTIVE | CORRECTIVE), `review_frequency`, `maturity_level`, `implementation_status`.

Regulatory Requirement

- **Table**: `compliance.requirements`
- **Fields**: `regulator`, `requirement_ref`, `summary_en`, `summary_ar`, `effective_from`, `effective_to`.

Evidence

- **Table**: `evidence.evidence_items` + `evidence.evidence_versions` + `evidence.evidence_links` + `evidence.permissions`.
- **Fields**: `external_id`, `title_en`, `title_ar`, `evidence_type`, `owner`, `expiry_date`, `current_version_no`, `chain_status` (VALID | BROKEN | UNVERIFIED), `chain_first_break_version`.

Assessment

- Generic assessment record per discipline:
- `risk.risk_assessments`

- `cyber.control_assessments`
- `scm.vendor_assessments`
- `privacy.dpias`
- `privacy.processor_assessments`
- `tprm.third_party_cyber_assessments`

BIA

- **Table**: `bcm.bia_records`
- **Fields**: `service_id`, `mtpd_hours`, `rto_hours`, `rpo_hours`, `mbco_pct`, `financial_impact_sar`, `regulatory_impact`, `reputational_impact`, `operational_impact`, `dependencies_json`, `last_reviewed_at`, `status`.

BCP

- **Table**: `bcm.bcm_plans`
- **Fields**: `plan_code`, `title_en`, `title_ar`, `service_id`, `team_json`, `comms_tree_json`, `alternate_site`, `version`, `status`.

DRP

- **Table**: `bcm.dr_plans`
- **Fields**: `plan_code`, `title_en`, `title_ar`, `system_name`, `rto_minutes`, `rpo_minutes`, `site_type`, `failover_steps_json`, `failback_steps_json`, `last_tested_at`, `next_test_due`, `last_test_outcome`, `status`.

Incident

- **Table**: `incident.incidents` (generic); `cyber.cyber_incidents` (cyber-specific)
- **Fields**: `incident_number`, `title_en`, `title_ar`, `severity`, `classification`, `detected_at`, `phase`, `assignee_user_id`, `impacted_assets_json`, `regulator_notified`, `notification_reference`.

Crisis Event

- **Table**: `bcm.invocations` + `bcm.crisis_*`

Data Breach

- **Table**: `privacy.data_breaches`
- **Fields**: `breach_external_id`, `detected_at`, `notified_at`, `sdaia_deadline_at` (72h), `data_subjects_count`, `categories`, `status`.

Cyber Incident

- **Table**: `cyber.cyber_incidents` (as above).

Corrective Action (CAPA)

- **Table**: `capa.tasks`
- **Fields**: `external_id`, `origin_type`, `origin_id`, `title_en`, `title_ar`, `capa_type` (CORRECTIVE | PREVENTIVE), `severity`, `owner`, `target_date`, `status` (OPEN → IN_PROGRESS → AWAITING_VERIFICATION → CLOSED / CANCELLED).

Issue

- Linked from incidents + audits + KRI breaches.

KRI

- **Table**: `risk.kri_definitions` + `risk.kri_breach_events`.

KPI

- Surface for reporting (mostly derived).

SLA

- **Table**: `scm.slas`
- **Fields**: `vendor_id`, `metric`, `target`, `breach_threshold`, `measurement_window`.

Exercise

- **Table**: `bcm.exercises`
- **Fields**: `title_en`, `title_ar`, `scenario`, `scheduled_for`, `participants`, `outcome`, `lessons_learned_id`.

Test (resilience)

- **Table**: `scm.supplier_resilience_tests` (new in V54).

Report

- Reports are generated artifacts persisted into Evidence and/or `reporting.scheduled_reports`.

Approval

- Cross-cutting concept implemented per workflow + per signature transaction.

Digital Signature Transaction

- **Table**: `signature.digital_signature_transactions`
- **Fields**: `external_id`, `related_entity_type`, `related_entity_id`, `signer_user_id`, `signer_name`, `provider`, `purpose`, `purpose_ar`, `signed_document_hash`, `certificate_reference`, `status` (REQUESTED → SIGNED / REJECTED / EXPIRED), `expiry_date`.

Audit Log

- **Table**: `audit.events`
- **Fields**: `event_id`, `organisation_id`, `actor_user_id`, `verb`, `entity_type`, `entity_id`, `before_json`, `after_json`, `ip_address`, `user_agent`, `at`.

Key relationships

- Organization 1 — N every business entity (`organisation_id` FK).
- Service 1 — N BIA 1 — N BCP 1 — N DRP.
- Service 1 — N CriticalProcess; CriticalProcess M — N Asset.
- Asset 1 — N Vulnerability.
- Asset 1 — N Cyber Incident (impacted-assets join).
- Cyber Incident 1 — 1 Data Breach (via cyber-bridge log).

- Vendor 1 — N AlternateSupplier (`primary_vendor_id`); 1 — N ExitPlan; 1 — N ResilienceTest; 1 — N FourthPartyExposure (`primary_vendor_name`).
- ProcessingActivity (ROPA) 1 — N PrivacyNotice (`linked_ropa_codes`); 1 — N CrossBorderTransfer (`ropa_code`); 1 — N DisposalCertificate (`related_entity_type='ropa'`); 1 — N DataSharingAgreement (`linked_ropa_codes`); 1 — N ProcessorAssessment (via `related_processor_id`).
- Risk M — N Control (`risk.risk_controls` linkage).
- Risk 1 — N Treatment Plan 1 — N CAPA.
- Evidence 1 — N EvidenceVersion 1 — N EvidenceLink (polymorphic to Control, Risk, Incident, BIA, BCP, etc.).
- Incident 1 — N RCA 1 — N CAPA.
- Committee 1 — N CommitteeMeeting.
- DigitalSignatureTransaction polymorphic to any workflow entity via `(related_entity_type, related_entity_id)`.
- AuditLog polymorphic across all entities.

Many-to-many tables

- `iam.user_roles` (user, role, organisation)
- `iam.role_permissions` (role, permission)
- `evidence.evidence_links` (evidence, target entity-type, target id, link-type)
- `cyber.control_assessments_assets` (assessment, asset)
- `risk.risk_controls` (risk, control)
- `compliance.policy_framework_mappings` (policy, framework)

Suggested API object names + DB table mapping

Domain	API DTO	Table
Risk	Risk	risk.risks
BIA	BiaRecord	bcm.bia_records
BCP	BcmPlan	bcm.bcm_plans
DRP	DisasterRecoveryPlan	bcm.dr_plans
Vendor	TprmVendorDto	scm.vendors
Alternate Supplier	AlternateSupplier	scm.alternate_suppliers
Exit Plan	ExitPlan	scm.exit_plans
Resilience Test	SupplierResilienceTest	scm.supplier_resilience_tests
Fourth-Party	FourthPartyExposure	scm.fourth_party_exposures
Contract Clause	ContractClause	scm.contract_clauses
Cyber Framework	CyberFramework	cyber.cyber_frameworks

Domain	API DTO	Table
Cyber Control	CyberControl	cyber.cyber_controls
Cyber Incident	CyberIncident	cyber.cyber_incidents
Asset	CyberAsset	cyber.cyber_assets
Vulnerability	Vulnerability	cyber.vulnerabilities
RCA	RootCauseAnalysis	cyber.root_cause_analyses
ROPA	ProcessingActivity	privacy.processing_activities
Privacy Notice	PrivacyNotice	privacy.privacy_notices
CBT	CrossBorderTransfer	privacy.cross_border_transfers
Disposal	DisposalCertificate	privacy.disposal_certificates
DSA	DataSharingAgreement	privacy.data_sharing_agreements
Processor DD	ProcessorAssessment	privacy.processor_assessments
TPRM Cyber	ThirdPartyCyberAssessment	tprm.third_party_cyber_assessments
Bridge Log	CyberPdplBridgeEvent	privacy.cyber_breach_bridge_log
CAPA	CapaTask	capa.tasks
Evidence	EvidenceItem	evidence.evidence_items
Signature	DigitalSignatureTransaction	signature.digital_signature_transactions
Committee	Committee	admin.committees
Committee Meeting	CommitteeMeeting	admin.committee_meetings
Emerging Risk	EmergingRisk	risk.emerging_risks
Risk Scenario	RiskScenario	risk.scenarios

Bilingual labels — sample dictionary

EN	AR
Organisation	■■■■■■■
User	■■■■■■■■
Role	■■■■■
Department	■■■■■■■
Committee	■■■■■■
Service	■■■■■■
Process	■■■■■■■
Asset	■■■■■
Risk	■■■■■■■■
Control	■■■■■■
Evidence	■■■■■■
Assessment	■■■■■■■

EN	AR
Incident	■■■■■■■
Data Breach	■■■ ■■■■■■■■
Cyber Incident	■■■■■■■ ■■■■■■■■■■
Corrective Action	■■■■■■■ ■■■■■■■■
Vendor / Supplier	■■■■■■
Contract	■■■■■
Dependency	■■■■■■■
Approval	■■■■■■■■
Signature	■■■■■■■
Audit Log	■■■ ■■■■■■■
Status	■■■■■■
Priority	■■■■■■■■
Owner	■■■■■■
Due Date	■■■■■ ■■■■■■■■■